

PERSONAL PROJECT PORTFOLIO

CareShield: NHS Nursing Staff Cybersecurity Awareness Campaign

Toochukwu Praise Ajoku

MSc Cyber Security | Keele University

Student Member, CIISec

June 2026

Target Group	Nursing staff: Royal Hospital (fictional NHS-style organisation)
Campaign Format	Mobile-optimised branching scenario e-learning module (Twine/Harlowe, 4 episodes)
Key Deliverables	User group analysis, 4-episode scenario module, Report Friction pathway, measurement framework
Standards Applied	ISO/IEC 27001:2022 Annex A.6.3, NIST SP 800-50 Rev. 1, UK GDPR / DPA 2018, WCAG 2.1 AA
Frameworks Applied	NCSC/ENISA Cybersecurity Culture Framework, Zimmermann et al. Human-Centred Cybersecurity (2024)
Skills Demonstrated	User-centred security design, behaviour change theory, standards alignment, programme evaluation

Executive Summary

This portfolio documents the design and development of **CareShield**, a mobile-optimised, branching scenario cybersecurity awareness campaign for nursing staff at a fictional Royal Hospital (RH).

Nurses are a high-risk user group because they face compliance budget overload [1], operate under clinical time pressure, and rely on a generic annual e-learning module that fails to meet ISO/IEC 27001:2022 Annex A.6.3 or NIST SP 800-50 Rev. 1 Tier 2 role-based training requirements. This produces documented workarounds (shared credentials, persistent sessions, and bypassed MFA) that expose the organisation to credential compromise, GDPR breach, and non-repudiation failure. The 2017 WannaCry attack, which disabled 80 NHS trusts, illustrates that this risk is not theoretical.

CareShield addresses both individual behaviour and the system conditions driving insecure workarounds through four 3–5 minute branching scenario episodes covering session management, phishing, UK GDPR data handling, and incident reporting. A Report Friction pathway embedded in the completion screen allows nurses to log usability barriers directly to IT, making the campaign a two-way organisational learning mechanism rather than one-directional compliance messaging.

Success is measured over six months across five metrics: phishing click rate, incident reporting volume, module retention, SIEM-detected credential-sharing events, and security culture perception, aligned to the NIST SP 800-50 Rev. 1 programme lifecycle.

Project Overview

1.1 User Group Analysis & Security Challenges

Nurses are selected as the target group based on three convergent risk factors: breadth of system access, operational time pressure, and structural incompatibility between clinical workflow and security control design. Nurses interact with multiple clinical systems across wards, each requiring independent authentication. This creates the compliance budget overload identified by Beautelement et al.: producing security fatigue: a state where repeated demands cause behavioural disengagement through cognitive overload, not indifference [1, 14].

Sasse and Flechais establish that security controls designed without reference to operational context predictably produce workarounds, as users prioritise patient care over security compliance [2]. Koppel et al. show nurses physically marked workstations to avoid re-authentication between interruptions [3]. Table 1 maps the four most consequential controls to their usability friction, workarounds, and organisational risk.

Table 1: Security Controls, Friction, Workarounds, and Risk

Security Control	Usability Friction	Workaround	Organisational Risk
Session timeout	Re-auth during emergencies	Shared login; persistent sessions	Non-repudiation failure; GDPR breach
Password rotation	Multiple systems; frequent resets	Reuse; sticky notes	Credential compromise; lateral movement
MFA	Extra step during urgent tasks	Shared OTPs; bypass requests	Control Weakened

RBAC	Access delays during transfers	Credential borrowing from colleagues	Access policy violation
------	--------------------------------	--------------------------------------	-------------------------

Under ISO/IEC 27001:2022 Annex A control A.6.3, organisations must provide awareness and training proportionate to role [4]. The RH's generic annual e-learning fails this standard. NIST SP 800-50 Rev. 1 identifies Tier 2 role-based training (not Tier 1 generic awareness) as the appropriate intervention for high-risk operational staff [5]. NIST SP 800-53 Rev. 5 controls AT-2 and AT-3 further mandate frequency and role alignment [6]. The WannaCry attack (2017), which disabled 80 NHS trusts, originated from poor access hygiene (not sophisticated exploitation), demonstrating this risk is not hypothetical [7].

Campaign Design: CareShield

2.1 Use Case Definition

CareShield is a mobile-optimised branching scenario e-learning campaign module comprising four episodes, designed specifically for RH nursing staff. Its core idea is drawn from Zimmermann et al.'s human-centred cybersecurity framework: nurses are not the weak link, but are expert users working inside poorly aligned systems, so the campaign addresses both behaviour and the design conditions that produce insecure workarounds [8].

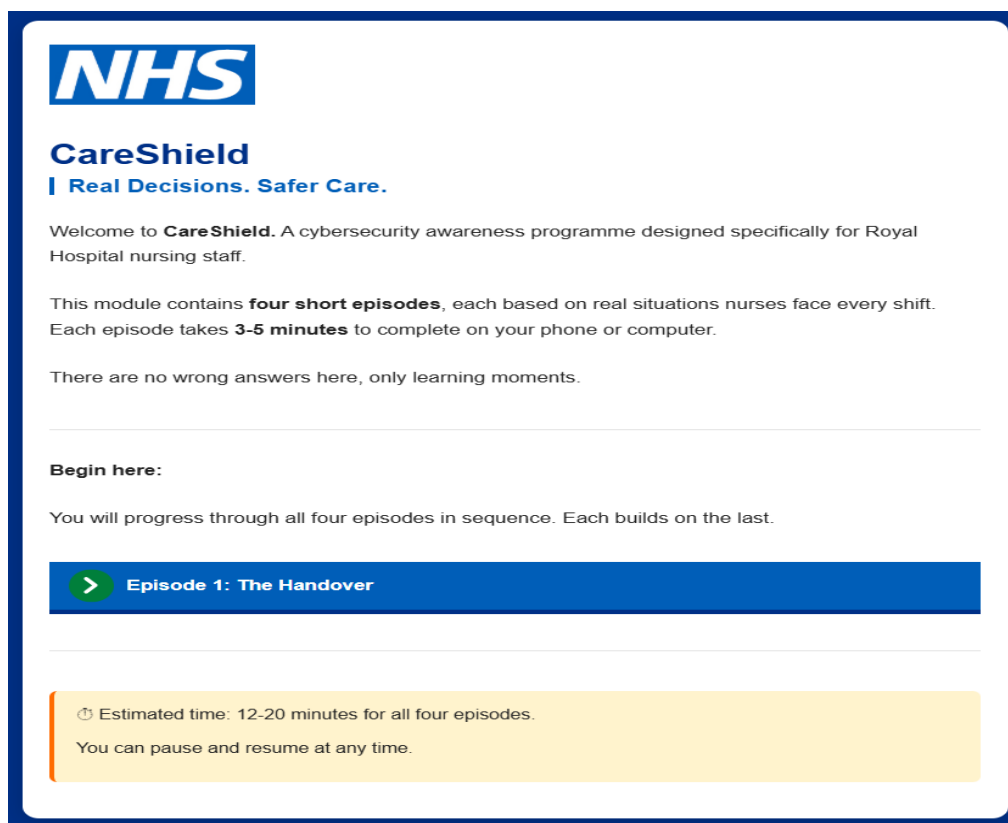


Figure 1: CareShield Start Screen: Module overview with NHS branding, 4-episode sequential structure, and non-punitive framing.

2.2 Root Cause Targeting

Following the NCSC/ENISA Cyber Security Culture framework [9], CareShield maps five root causes to campaign components:

Table 2: Root Causes and Campaign Responses

Root Cause	Theoretical Basis	Campaign Response
Workflow-security conflict	Koppel et al. [3]; Sasse and Flechais [2]	'Report Friction' pathway: nurses log usability barriers to IT
Compliance budget exhaustion	Beautement et al. [1]	3-5 minute microlearning at shift-change
Security treated as secondary	Sasse and Flechais [2]	Teaches safe shortcuts such as emergency override
Low personal relevance	Nifakos et al. [10]	Scenarios use RH characters, real EHR interfaces, NHS-specific phishing templates
Low psychological safety	Zimmermann et al. [8]	Module 4 reframes reporting as professional duty

2.3 Artefact: Branching Scenario Module

NHS

Episode 1 of 4 | 🗑️ Session Management

| The Handover

It is 02:14. Mr Okafor is being transferred urgently to the ICU. You reach the EHR terminal at the nurses' station, but it has timed out after 3 minutes of inactivity. Your login credentials are on the ward system, but the re-authentication screen is asking for your smartcard, which you left at the previous terminal.

Your colleague Priya is standing next to you. She is already logged in on her own session on an adjacent terminal. The ICU team is waiting.

Every second matters. What do you do?

- Use Priya's login; she's right there and agrees to it
- Activate the emergency override protocol on the timed-out terminal
- Go back to the previous terminal to retrieve your smartcard

Figure 2: Episode 1 Decision Screen (The Handover): Three realistic branching choices under time pressure.

The branching format is selected over passive formats (posters, slide decks) because it places learners in active decision roles, directly building security self-efficacy; the strongest predictor of sustained compliance under fatigue conditions identified by Malik et al. [11]. Episodes are completable in 3–5 minutes on mobile during breaks. The module is WCAG 2.1 AA compliant, in plain NHS English, with non-punitive framing throughout [12].

Table 3: Module Structure

Episode	Scenario	Root Cause	Security Concept
1: The Handover	Session timeout during emergency patient transfer	Structural incompatibility	Session management; non-repudiation; emergency access protocol
2: The NHS Email	Fake NHS Digital email requesting urgent password verification	Time-pressure exploitation	Phishing recognition; reporting pathway
3: The WhatsApp Photo	Nurse photographs medication chart on personal phone to share with off-site GP	Compliance budget; BYOD	UK GDPR; data minimisation; approved secure channels
4: The Near Miss	Nurse ignores a shared terminal left logged in; visitor gains access	Psychological safety	Incident reporting; shared accountability; CQC/ICO implications

Each branch shows realistic consequences such as audit logs, reporting forms, or breach implications so the learner sees organisational impact rather than only policy language [8]. The Report Friction pathway lets nurses log usability barriers to IT, making the campaign a two-way improvement mechanism, not one-way compliance messaging.

2.4 Measurable Outcomes

Consistent with the NIST SP 800-50 Rev. 1 programme lifecycle (Plan–Analyse–Design–Develop–Implement–Assess) [5], CareShield defines five measurable outcomes evaluated across a six-month post-deployment window, applying Karamahmutoglu and Gokturk's usability-security measurement methodology [13]:

Table 4: Measurement Framework

Metric	Method	Target	Horizon
Phishing click rate	Simulated NHS phishing campaign	≤10% by M6 vs Week 0 baseline	Baseline → M3 → M6
Incident reporting rate	Helpdesk ticket categorisation	≥30% increase from baseline	Monthly

Module completion & retention	In-module quiz + M3 reassessment	$\geq 80\%$ pass; $\leq 15\%$ knowledge decay	Immediate + M3
Credential-sharing events	SIEM anomaly alerts	50% reduction in shared-session events	Quarterly
Security culture perception	Anonymous ENISA survey	Shift from compliance-as-burden to compliance-as-normal	Annual

Reflection & Conclusion

CareShield is designed around the view that sustainable security behaviour in clinical environments depends on changing system conditions as well as individual decisions. The branching format was chosen over posters (awareness-only), phishing simulations (diagnostic, not instructional [11]), and facilitator-dependent formats (incompatible with shift patterns), because it builds self-efficacy through active decision-making; the strongest predictor of sustained compliance under fatigue [11].

Three trade-off decisions shaped the design. First, micro-duration (3-5 minutes) delivery reduces burden but limits depth, so each episode focuses on one high-risk workaround. Second, RH-specific realism improves relevance but reduces portability to other hospitals. Third, the Report Friction mechanism increases organisational learning, but it also requires IT responsiveness to maintain staff trust. Overall, the campaign links user behaviour to organisational risk, integrates literature critically, and provides a measurable, professionally presented artefact grounded in usable security principles [2], [5], [8]. The micro-duration format and shift-change scheduling specifically avoid placing additional cognitive burden on nursing staff during active patient care, addressing the compliance budget constraint directly.

References

- [1] A. Beautelement, M. A. Sasse, and M. Wonham, "The compliance budget: Managing security behaviour in organisations," in *Proc. NSPW 2008*, pp. 47–58. [Online]. Available: <https://discovery.ucl.ac.uk/1301853/>
- [2] M. A. Sasse and I. Flechais, "Usable security: Why do we need it? How do we get it?," in *Security and Usability*, O'Reilly Media, 2005, pp. 13–30. [Online]. Available: <https://discovery.ucl.ac.uk/id/eprint/20345/>
- [3] R. Koppel, S. Smith, J. Blythe, and V. Kothari, "Workarounds to computer access in healthcare organisations: You want my password or a dead patient?," in *Proc. HCI and Usable Privacy and Security Workshop*, 2015, pp. 215–220. [Online]. Available: <https://www.cs.dartmouth.edu/~sws/pubs/ksbk15-draft.pdf>.
- [4] International Organization for Standardization, *Information Security Management Systems - Requirements*, ISO/IEC 27001:2022, Geneva, Switzerland: ISO, 2022. [Online]. Available: <https://www.iso.org/standard/27001>.
- [5] National Institute of Standards and Technology, *Building a Cybersecurity and Privacy Learning Program*, NIST SP 800-50 Rev. 1, Gaithersburg, MD, USA: NIST, Sep. 2024. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-50r1>.
- [6] National Institute of Standards and Technology, *Security and Privacy Controls for Information Systems and Organizations*, NIST SP 800-53 Rev. 5, Gaithersburg, MD, USA: NIST, 2020. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-53r5>.
- [7] National Audit Office, "Investigation: WannaCry cyber attack and the NHS," NAO, London, Rep. HC 414, Apr. 2018. [Online]. Available: <https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/>
- [8] V. Zimmermann et al., "Human-centered cybersecurity revisited: From enemies to partners," *Commun. ACM*, vol. 67, no. 11, pp. 72–81, Nov. 2024. [Online]. Available: <https://www.research-collection.ethz.ch/entities/publication/45c793c2-2dc9-4d2d-800d-061979e027eb>
- [9] European Union Agency for Cybersecurity (ENISA), *Cybersecurity Culture Guidelines: Behavioural Aspects of Cybersecurity*, ENISA, Athens, Greece, Dec. 2018. [Online]. Available: <https://www.enisa.europa.eu/publications/cybersecurity-culture-guidelines-behavioural-aspects-of-cybersecurity>

-
- [10] S. Nifakos et al., "Influence of human factors on cyber security within healthcare organisations: A systematic review," *Sensors*, vol. 21, no. 15, p. 5119, Jul. 2021. [Online]. Available: <https://doi.org/10.3390/s21155119>.
- [11] A. Malik, S. Goel, and S. Sinha, "Security fatigue: Manifestation of emotional exhaustion and cynicism by depletion of self-regulation capacity," *European Journal of Information Systems*, pp. 1–20, Feb. 2026. [Online]. Available: <https://doi.org/10.1080/0960085x.2026.2621809>.
- [12] S. N. Tambe-Jagtap, "Human-centric cybersecurity: Understanding and mitigating the role of human error in cyber incidents," *SHIFRA*, vol. 2, no. 1, pp. 1–12, Jul. 2023.
- [13] I. Karamahmutoglu and M. Gokturk, "A systematic approach to measure usability and security trade-off," in *Proc. HORA 2024*, Istanbul, Turkey, May 2024, pp. 1–6. [Online]. Available: <https://www.semanticscholar.org/paper/A-Systematic-Approach-to-Measure-Usability-and-Karamahmutoglu-Gokturk/c1874efe2cb29d9ffe71e57ca09af9e956cfc4c5>
- [14] S. Furnell and K. L. Thomson, "Recognising and addressing 'security fatigue'," *Computer Fraud & Security*, vol. 2009, no. 11, pp. 7–11, Nov. 2009. [Online]. Available: <https://ro.ecu.edu.au/ecuworks/371/>